

Operational Security and Incident Response

Giuseppe Pisano
g.pisano@unibo.it

Healthcare Data Privacy and Security

August, 2026



S.K.I.L.L.E.D — AID013244/04/2

Strategic Knowledge and Inclusive Lifelong Learning in the health sector for youth Employability and Development

- 1 Operational Security Mindset
- 2 Scams, Phishing, and Human Entry Points
- 3 Ransomware
- 4 Backups and Recovery
- 5 Incident Response
- 6 Breach Response and Communication
- 7 Tabletop Exercise

8 Final Integration

Learning path

We turn the previous lessons into operational habits: prevent common incidents, prepare backups, detect ransomware, contain compromise, recover safely, and communicate clearly.

Hospital storyline

At 07:20 on Monday, St. Isidore Hospital discovers that the EHR is unavailable, shared folders are encrypted, and a nurse reports a suspicious email attachment. The question is no longer theoretical: how does the hospital keep treating patients?

Connection

Security controls only matter if they survive real work. Ransomware, scams, misconfiguration, lost devices, and vendor failures test whether authentication, access control, encryption, networking, logging, backups, and privacy governance were implemented as a system.

Running example

A strong password policy helps before the incident. Network segmentation helps during the incident. Backups determine recovery. Privacy governance shapes breach notification and patient communication.

Operational Security Mindset

Section Context: Operational Security Mindset

What we are talking about

Operational security is the daily practice of keeping systems safe enough to support care. It is less glamorous than cryptography or firewalls, but many hospital incidents begin with routine failures: weak passwords, unpatched systems, unclear ownership, and untested backups.

Hospital lens

The hospital does not need perfect security. It needs resilient security: controls that reduce the chance of incidents and limit harm when incidents still happen.

From Framework to Action

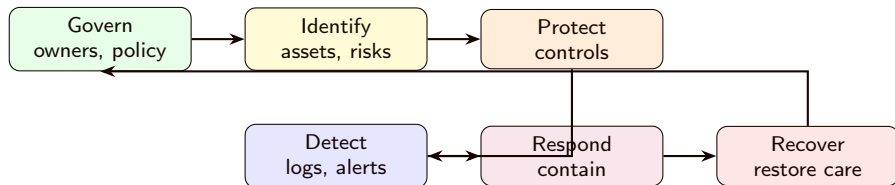
NIST CSF 2.0

The NIST Cybersecurity Framework organizes cybersecurity outcomes around **govern, identify, protect, detect, respond, and recover** [Pascoe et al., 2024].

Running example

For St. Isidore Hospital, governance means assigning owners. Identify means knowing critical systems. Protect means MFA and segmentation. Detect means logs and alerts. Respond means containment. Recover means restoring care safely.

Operational Security Scheme



The Hospital Asset Question

Identify first

You cannot protect what nobody owns or understands. Operational security starts with an inventory: systems, users, vendors, backups, network paths, data types, dependencies, and critical clinical workflows.

Running example

If the EHR is down, can the emergency department still see allergies? If the laboratory system is down, can clinicians still receive urgent results? These are asset and dependency questions.

Recap: Operational Security Mindset

Takeaways

- Operational security turns controls into repeatable work.
- Governance and ownership matter as much as tools.
- Healthcare resilience starts from clinical dependencies.

In St. Isidore Hospital

St. Isidore maps systems by patient-care impact, not only by technical category.

Scams, Phishing, and Human Entry Points

Section Context: Scams and Phishing

What we are talking about

Many incidents start with social engineering: a person is tricked into opening a file, entering a password, approving an MFA request, paying a fake invoice, or granting remote access.

Hospital lens

Attackers do not need to defeat encryption if they can convince a busy employee to run malware or share credentials.

Common Healthcare Scams

Scam	Hospital example
Phishing attachment	“Updated rota” spreadsheet installs malware
Credential harvesting	fake patient portal login page steals passwords
MFA fatigue	repeated push prompts until a user accepts
Invoice fraud	supplier bank account change request
Fake IT support	caller asks nurse to install remote tool
Executive impersonation	urgent request to send patient or payroll file

What Staff Should Notice

Red flags

Unexpected urgency, mismatched sender domains, unusual file types, password requests, links to login pages, pressure to bypass procedure, and “keep this confidential” instructions should slow the user down.

Running example

A message says: “Your mailbox is full, login now or lose access before surgery schedule upload.” The right action is to report it, not to click.

Make Reporting Easy

Operational advice

Training is not enough if reporting is slow or punitive. Staff need a simple way to report suspicious emails, calls, files, and logins, and they need feedback that reporting helped.

Running example

St. Isidore Hospital adds a report-phishing button and a phone number for urgent suspicious calls. The security team treats reports as early-warning signals, not as embarrassment.

Controls That Reduce Social Engineering Impact



Defense in depth

Use MFA, disable macros where possible, filter email, block known malicious domains, limit admin rights, restrict remote tools, monitor unusual login locations, and require out-of-band verification for payment or vendor-account changes.

Running example

If a receptionist enters credentials into a fake page, MFA and conditional access may prevent login. If the attacker still logs in, least privilege limits what the account can access.

Recap: Scams, Phishing, and Human Entry Points



Takeaways

- Scams target attention, pressure, and routine.
- Good reporting is a security control.
- Technical controls reduce the blast radius of human mistakes.

In St. Isidore Hospital

St. Isidore designs procedures so staff can pause, verify, and report without delaying care.

Ransomware

Section Context: Ransomware

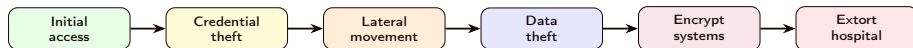
What we are talking about

Ransomware is an operational crisis: attackers may steal data, encrypt systems, disrupt care, and pressure the organization through extortion. Hospitals are attractive because downtime can affect patient safety.

Hospital lens

The ransom note is only the visible symptom. The incident may include credential theft, lateral movement, backup deletion, data exfiltration, and weeks of recovery work.

Typical Ransomware Chain



Why Ransomware Hits Healthcare Hard

Operational fragility

Hospitals often depend on 24/7 availability, legacy systems, shared workstations, medical devices, third-party vendors, and urgent workflows. Attackers exploit the fact that downtime is expensive and dangerous.

Running example

If radiology images, medication orders, and lab results are unavailable, clinicians must switch to manual processes while still avoiding medication errors and missed diagnoses.

Preventive Priorities

CISA-style basics

Ransomware prevention emphasizes MFA, patching, secure remote access, least privilege, network segmentation, email security, endpoint protection, logging, vulnerability management, and protected backups [CISA, 2023].

Running example

An exposed remote desktop service is a door. A flat hospital network is a corridor. Domain admin reuse is a master key. Ransomware prevention tries to remove all three.

Early Warning Signs

Detection clues

Unusual login patterns, disabled security tools, mass file renaming, unexpected administrative commands, large outbound transfers, new scheduled tasks, and backup failures can indicate an attack before encryption spreads.

Running example

At 03:10, a lab workstation starts authenticating to many file shares. That is not normal lab work; it is a signal to investigate quickly.

Recap: Ransomware

Takeaways

- Ransomware is usually a chain, not a single event.
- Prevention combines identity, patching, segmentation, monitoring, and backups.
- Early detection can prevent encryption from becoming hospital-wide downtime.

In St. Isidore Hospital

St. Isidore treats ransomware as a patient-safety risk, not only an IT problem.

Backups and Recovery

Section Context: Backups and Recovery

What we are talking about

Backups are not a folder where old files live. They are a recovery capability. A backup strategy must define what is backed up, how often, where it is stored, who can delete it, and how restoration is tested.

Hospital lens

The question is not “do we have backups?” The question is “can we restore the EHR, lab results, and medication records fast enough to continue safe care?”

3-2-1 and Immutability

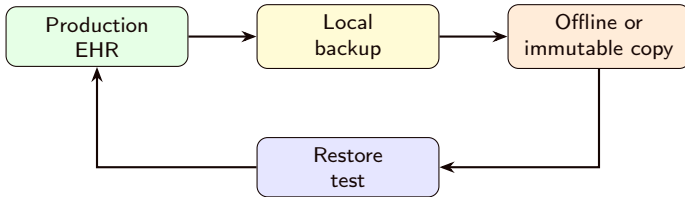
Practical rule

A common backup pattern is **3-2-1**: keep at least three copies, on two different media or platforms, with one copy offline or otherwise isolated. For ransomware, immutable or protected backups are critical because attackers try to delete backups first.

Running example

St. Isidore Hospital keeps production EHR data, local backup storage, and an immutable cloud or offline copy with separate credentials and tested restore procedures.

Backup Design Scheme



RPO and RTO

Two recovery questions

Recovery Point Objective asks how much data loss is tolerable.

Recovery Time Objective asks how long the service can be down before harm becomes unacceptable.

Running example

For appointment reminders, losing one day may be tolerable. For medication administration records, the acceptable loss and downtime may be much lower.

Restore Testing

The uncomfortable truth

A backup that has never been restored is only a hope. Restore tests should verify data integrity, application compatibility, credentials, timing, and clinical usability.

Running example

Restoring a database is not enough if OpenHospital cannot start, lab interfaces cannot reconnect, or staff do not know which paper forms to use during downtime.

Downtime Procedures

Business continuity

Recovery is not only technical restoration. Hospitals need downtime forms, manual medication checks, patient identification procedures, laboratory-result communication paths, and a plan for entering paper records back into the system after recovery.

Running example

When the EHR is unavailable, St. Isidore Hospital moves to preprinted admission forms, direct phone calls for critical lab values, and a later reconciliation process.

Recap: Backups and Recovery

Takeaways

- Backups are useful only if restoration works.
- Immutable or isolated backups limit ransomware leverage.
- Clinical downtime procedures are part of recovery.

In St. Isidore Hospital

St. Isidore measures backup quality by restored care, not by backup-job success emails.

Incident Response

Section Context: Incident Response

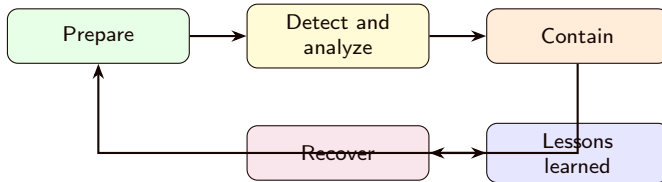
What we are talking about

Incident response is the organized process for handling security events before they become larger harm. NIST incident handling guidance emphasizes preparation, detection and analysis, containment, eradication, recovery, and lessons learned [Cichonski et al., 2012].

Hospital lens

During an incident, improvisation is expensive. A prepared response team knows who can disconnect systems, who talks to clinicians, who preserves evidence, and who informs leadership.

Incident Response Life Cycle



Prepare Before the Incident

Minimum preparation

Define contacts, roles, escalation paths, legal and privacy contacts, vendor contacts, evidence handling, emergency procurement, downtime procedures, backup restoration steps, and communication templates.

Running example

If the EHR is encrypted at 07:20, the hospital should not spend the first hour asking who has the cloud backup password.

Detect and Analyze

First questions

What happened? Which systems are affected? Is data encrypted, stolen, or only unavailable? Is the attack still active? Which clinical services are impacted? What evidence must be preserved?

Running example

The team compares endpoint alerts, proxy logs, authentication logs, file-server events, backup logs, and staff reports to distinguish malware from an isolated system failure.

Containment

Limit harm

Containment may include isolating endpoints, disabling compromised accounts, blocking command and control domains, disconnecting network segments, pausing risky integrations, and preserving backup copies.

Running example

Disconnecting the laboratory subnet may slow results, but leaving it connected may allow ransomware to reach analyzers and file shares. The decision must include clinical leadership.

Eradication and Recovery

Return safely

Remove malware, close exploited paths, rebuild systems when needed, rotate credentials, validate backups, restore services in priority order, and monitor carefully for reinfection.

Running example

Restoring the EHR before resetting stolen admin credentials may restore the attacker too.

Recap: Incident Response

Takeaways

- Incident response is planned decision-making under pressure.
- Containment decisions must include patient-care impact.
- Recovery must avoid reintroducing the attacker.

In St. Isidore Hospital

St. Isidore responds as a hospital, not as an isolated IT department.

Breach Response and Communication

Section Context: Breach Response

What we are talking about

A security incident becomes a privacy breach when personal data is exposed, lost, altered, accessed without authorization, or made unavailable in a way that creates risk for people.

Hospital lens

Encrypted file shares may be an availability incident. If attackers also copied patient records, it is a confidentiality breach. If medication data was corrupted, integrity and safety are involved.

Breach Triage Questions

Assess impact

Which data was involved? Whose data? Was it encrypted or readable? Was it copied? Could patients suffer discrimination, fraud, stigma, physical harm, or loss of confidentiality? Which laws, contracts, or ethics duties apply?

Running example

A leaked appointment list for dermatology is serious. A leaked list for oncology, HIV, psychiatry, or maternity care may create additional stigma and safety risks.

Who Needs to Know?

Audience	Communication need
Clinical teams	what systems are down, safe workarounds, escalation path
Leadership	risk, resources, decisions, legal exposure, patient impact
IT and vendors	technical facts, containment, restoration priorities
Privacy/legal	breach assessment, notifications, evidence, deadlines
Patients	clear facts, risks, support actions, contact point
Regulators	required notice, scope, mitigation, follow-up

Incident Communication Principles

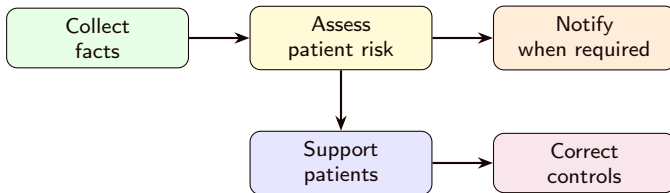
How to speak

Communications should be timely, accurate, calm, consistent, and honest about uncertainty. Avoid speculation, blame, technical jargon, and promises that recovery teams cannot guarantee.

Running example

“We are investigating unauthorized access to some patient records” is better than “nothing was stolen” before evidence exists.

Breach Response Scheme



Recap: Breach Response and Communication

Takeaways

- Breach response is about harm to people, not only harm to servers.
- Communication must be coordinated and evidence-based.
- Privacy, legal, clinical, and technical teams must work together.

In St. Isidore Hospital

St. Isidore communicates to preserve patient safety, trust, and legal accountability.

Tabletop Exercise

Section Context: Tabletop Exercise

What we are talking about

A tabletop exercise tests decisions without causing real downtime. Participants walk through a scenario, identify missing information, make choices, and record improvements.

Hospital lens

The aim is not to embarrass anyone. The aim is to discover gaps before attackers discover them.

Scenario: Monday 07:20

Inject 1

The emergency department cannot open the EHR. The file server shows ransom notes. A nurse reports that she opened a spreadsheet called `urgent_rota.xlsx`. The laboratory says some results are delayed.

Decision

Who is incident commander? Which systems are isolated first? What do clinicians do for current patients? What evidence must not be destroyed?

Scenario: Monday 08:10

Inject 2

IT finds suspicious admin logins during the night and large outbound transfers from a server. A local journalist calls reception asking whether patient records were stolen.

Decision

Who speaks externally? What can be said now? Who assesses breach notification duties? Are backups safe, and who verifies that?

Scenario: Monday 10:30

Inject 3

Backups exist, but the most recent restore test was eight months ago. The ransom note threatens to publish oncology and maternity records. Clinical teams are using paper forms.

Decision

Which service is restored first? How are paper records reconciled? How are patients supported if their data may have been exposed?

Exercise Output

What to produce

The team should produce an incident timeline, affected systems list, containment decisions, clinical downtime plan, backup status, communication plan, breach triage, and lessons-learned actions.

Running example

One useful action may be simple: “test restore every month and document the time needed for EHR, lab, and file-server recovery.”

Recap: Tabletop Exercise

Takeaways

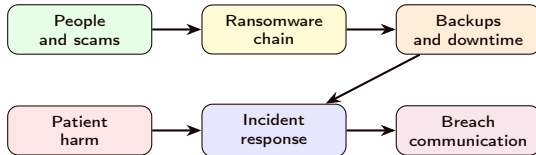
- Tabletop exercises expose gaps safely.
- Decisions must include patient-care priorities.
- The output is an improvement plan, not a theatrical performance.

In St. Isidore Hospital

St. Isidore practices the day it hopes never arrives.

Final Integration

Final Concept Map



Final Recap



Core lesson

Operational security is where the course becomes real. Prevention reduces incidents, detection buys time, response limits damage, backups enable recovery, and communication protects patients and trust.

In St. Isidore Hospital

St. Isidore Hospital cannot promise that incidents will never happen. It can promise preparation: trained staff, tested backups, segmented networks, useful logs, practiced response, and honest communication.

References I

[Cichonski et al., 2012] Cichonski, P., Millar, T., Grance, T., and Scarfone, K. (2012).

Computer security incident handling guide.

Revision 2 was withdrawn in 2025 after being superseded, but remains a common reference for incident handling terminology

DOI:10.6028/NIST.SP.800-61r2.

[CISA, 2023] CISA (2023).

Stopransomware guide

<https://www.cisa.gov/stopransomware>.

[Pascoe et al., 2024] Pascoe, C., Quinn, S., and Scarfone, K. (2024).

The nist cybersecurity framework 2.0

DOI:10.6028/NIST.CSWP.29.